

Audyt bezpieczeństwa i hardening systemu Debian 13

Raport bezpieczeństwa – Audyt i hardening systemu Debian 13

Autor: Monika Campoli

Nr albumu: 163319

1. Executive Summary

Celem projektu było przeprowadzenie audytu bezpieczeństwa systemu Debian 13, identyfikacja podatności oraz wdrożenie działań hardeningowych zwiększających poziom bezpieczeństwa systemu operacyjnego

Audyt został wykonany przy użyciu narzędzia Lynis 3.1.4 oraz natywnych narzędzi systemowych Linux. Na podstawie wyników wykryto wiele problemów bezpieczeństwa, m.in. brak aktywnego firewalla, nieprawidłową konfigurację SSH, brak mechanizmów monitorowania integralności plików, brak ochrony przed atakami brute-force oraz brak automatycznych aktualizacji bezpieczeństwa.

W ramach projektu wdrożono 11 poprawek bezpieczeństwa obejmujących konfigurację sieci, usług systemowych, monitorowania oraz hardening jądra systemu.

Efektom przeprowadzonych działań było zwiększenie wyniku Lynis Hardening Index z 63 punktów na 100 do 82 punktów na 100 oraz eliminacja wszystkich warningów wykrytych podczas audytu początkowego. System po wdrożeniu poprawek posiada aktywny firewall, ochronę SSH, monitoring integralności plików, rejestrowanie zdarzeń bezpieczeństwa, automatyczne aktualizacje bezpieczeństwa oraz utwardzoną konfigurację jądra Linux.

2. Cel projektu

Celem projektu było przeprowadzenie audytu bezpieczeństwa systemu Debian 13, analiza wykrytych podatności, wdrożenie działań hardeningowych, porównanie wyników audytu przed i po wdrożeniu zabezpieczeń oraz zwiększenie odporności systemu na ataki sieciowe i lokalne. Projekt miał charakter praktyczny i skupiał się na rzeczywistym zwiększeniu poziomu bezpieczeństwa systemu operacyjnego Linux.

3. Zakres i metodologia

3.1 Zakres testów

Audyt obejmował konfigurację sieci, konfigurację SSH, politykę haseł, mechanizmy logowania, integralność plików, konfigurację jądra systemu, automatyczne aktualizacje oraz mechanizmy ochrony przed atakami brute-force. Nie wykonywano testów exploitacyjnych, analizy aplikacji webowych, testów malware ani testów penetracyjnych sieci zewnętrznej.

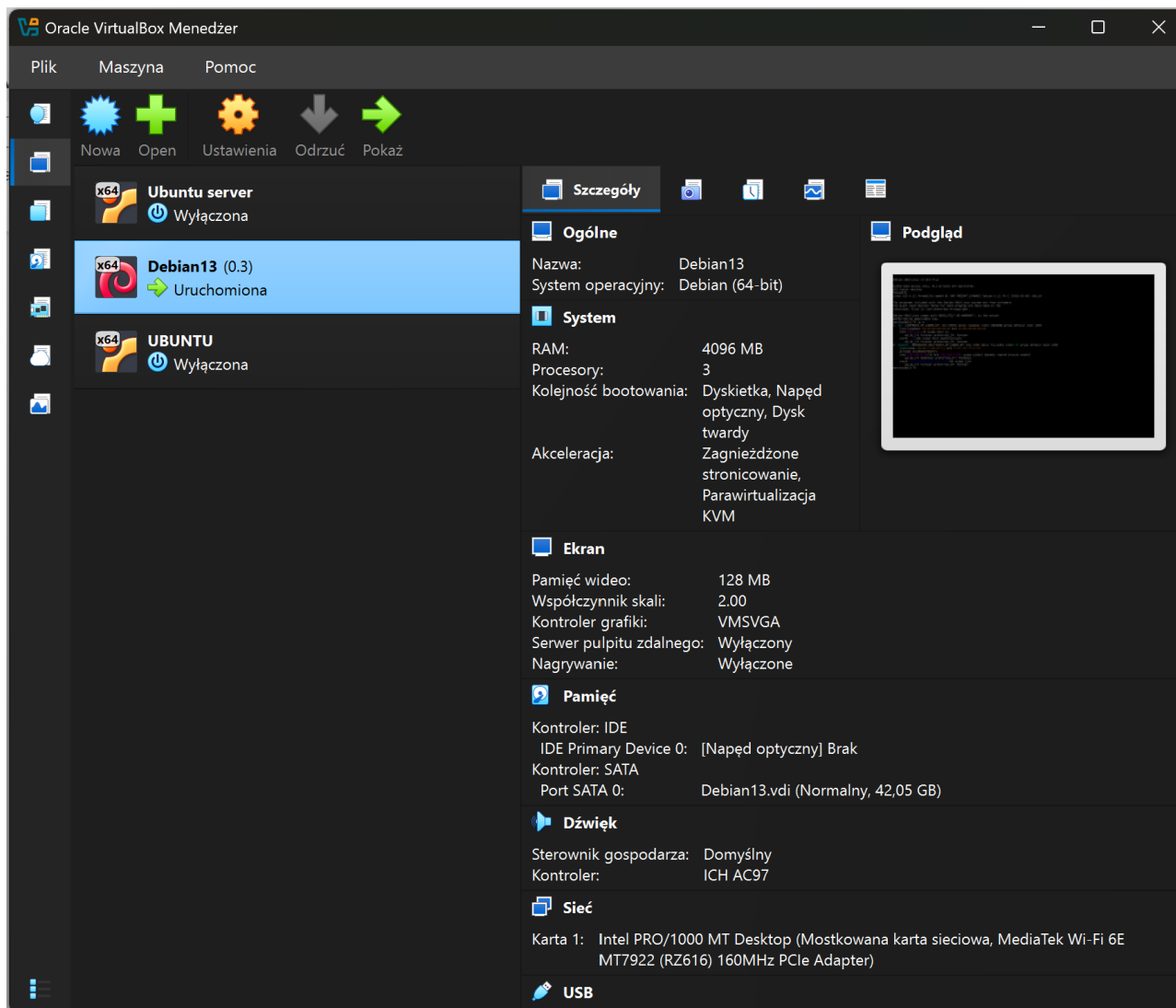
3.2 Metodologia

Audyt bezpieczeństwa wykonano metodą local security audit z wykorzystaniem narzędzi Lynis 3.1.4, UFW, Fail2ban, Auditd, AIDE, systemctl, sshd, auditctl oraz sysctl.

Proces projektu przebiegał w następujących etapach: audyt początkowy systemu, analiza wyników Lynis, identyfikacja podatności, wdrożenie poprawek bezpieczeństwa, testowanie zmian, ponowny audyt systemu, porównanie wyników przed i po oraz automatyzacja audytu przez CRON.

3.3 Środowisko testowe

System operacyjny Debian 13 z jądrem w wersji 6.12.74+deb13+1 na architekturze x86_64. System działał w środowisku maszyny wirtualnej. Do audytu użyto Lynis 3.1.4, jako firewall służył UFW, do ochrony przed brute-force Fail2ban, do monitorowania Auditd i AIDE, a do logowania rsyslog.



1. Virtual Box- Maszyna Virtualna – Debian 13.

Plik : VM Debian 13.png

4. Podatności – opis i naprawa

Podatność 1: Brak aktywnego firewalla - Identyfikator: FIX-001

System nie posiadał aktywnego mechanizmu filtrowania ruchu sieciowego. Usługa UFW była nieaktywna, co oznaczało, że wszystkie porty były potencjalnie dostępne z sieci.

W związku z powyższym zakwalifikowano podatność jako wysokie zagrożenie. Atakujący może skanować porty, identyfikować usługi, wykonywać próby ataków brute-force oraz wykorzystywać podatności sieciowe.

Wykonanie komendy `lynis audit system` oraz `ufw status` wykazało, że firewall jest nieaktywny.

Wdrożono firewalla UFW z polityką domyślnie blokującą ruch przychodzący, zezwalającą na ruch wychodzący oraz otwierającą jedynie port 2222 dla usługi SSH.

Krok 1: Aktualizacja listy pakietów oraz instalacja UFW

```
apt update
```

```
apt install ufw -y
```

Krok 3: Ustawienie domyślnej polityki blokowania ruchu przychodzącego oraz domyślnej polityki zezwalającej na ruch wychodzący.

```
ufw default deny incoming
```

```
ufw default allow outgoing
```

Krok 5: Otwarcie portu dla SSH (port 2222) oraz włączenie firewalla.

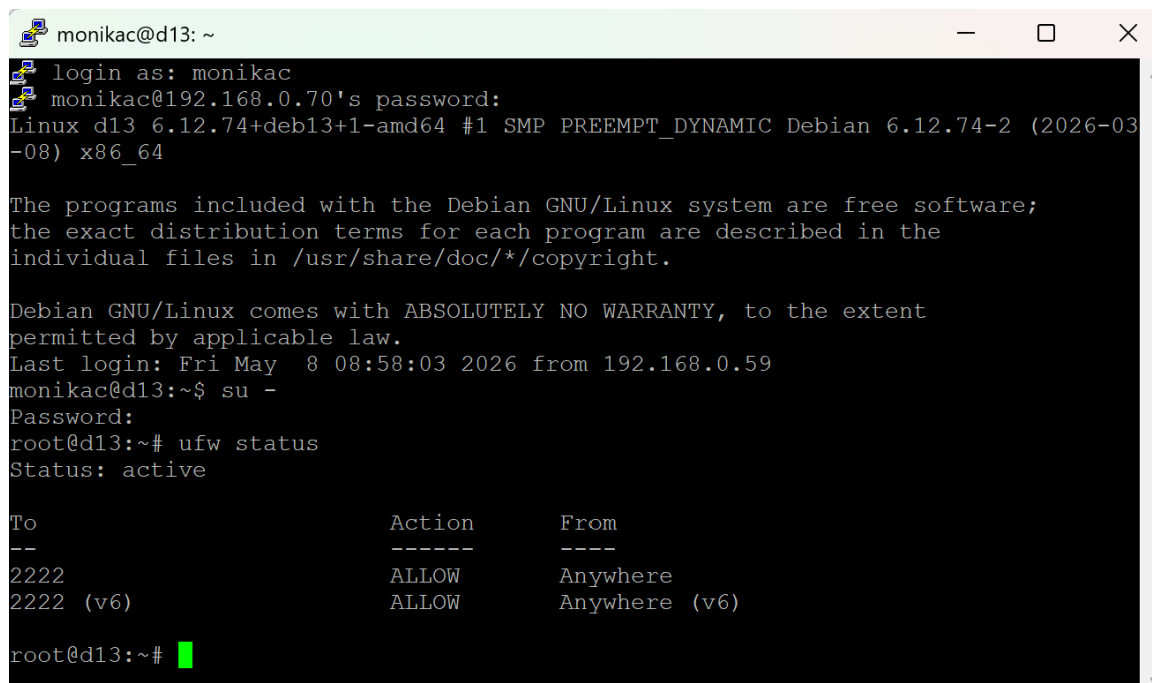
```
ufw allow 2222/tcp
```

```
ufw enable
```

Krok 7: Weryfikacja statusu.

```
ufw status verbose
```

W efekcie system zyskał filtrowanie ruchu, ograniczenie powierzchni ataku oraz blokowanie nieautoryzowanych połączeń.



```
monikac@d13: ~  
login as: monikac  
monikac@192.168.0.70's password:  
Linux d13 6.12.74+deb13+1-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.12.74-2 (2026-03-08) x86_64  
  
The programs included with the Debian GNU/Linux system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent  
permitted by applicable law.  
Last login: Fri May 8 08:58:03 2026 from 192.168.0.59  
monikac@d13:~$ su -  
Password:  
root@d13:~# ufw status  
Status: active  
  
To Action From  
-- -- --  
2222 ALLOW Anywhere  
2222 (v6) ALLOW Anywhere (v6)  
  
root@d13:~#
```

2. **Firewall UFW:** Zrzut ekranu z komendy `ufw status verbose`. Widoczny status aktywny, domyślnie blokowanie ruchu przychodzącego oraz otwarty port 2222.

Plik: results/UFW-status.png.

Podatność 2: Niezabezpieczona konfiguracja SSH - Identyfikator: FIX-002

Usługa SSH działała na domyślnym porcie 22, z włączonymi niebezpiecznymi opcjami X11Forwarding i AllowAgentForwarding oraz bez limitu prób logowania.

Zakwalifikowano podatność jako średnie wchodzące do wysokiego ryzyka. Możliwe były ataki brute-force, automatyczne skanowanie oraz nadużycie funkcji forwarding SSH.

Komenda `sshd -T` wykazała, że SSH działa na porcie 22, limit prób logowania wynosi 6, a opcje X11Forwarding i AllowAgentForwarding są włączone.

W ramach naprawy zmieniono port SSH na 2222, ustawiono limit prób logowania na 3, wyłączono X11Forwarding, AllowAgentForwarding oraz TCPKeepAlive, a poziom logowania podniesiono do VERBOSE.

Krok 1: Edycja pliku konfiguracyjnego SSH.

```
nano /etc/ssh/sshd_config
```

Krok 2: Wprowadzenie zmian w pliku konfiguracyjnym:

- Zmiana portu: Port 2222
- Ograniczenie prób logowania: MaxAuthTries 3
- Wyłączenie X11Forwarding: X11Forwarding no
- Wyłączenie AllowAgentForwarding: AllowAgentForwarding no
- Wyłączenie TCPKeepAlive: TCPKeepAlive no
- Podniesienie poziomu logowania: LogLevel VERBOSE

Krok 4: Restart usługi SSH.

```
systemctl restart ssh
```

Krok 5: Aktualizacja firewalla (dodanie nowego portu) oraz usunięcie starego portu 22.

```
ufw allow 2222/tcp
```

```
ufw delete allow 22/tcp
```

Krok 7: Przeładowanie firewalla.

```
ufw reload
```

Krok 8: Weryfikacja konfiguracji

```
sshd -T | grep -E "port|maxauthtries|x11forwarding|allowagentforwarding|tcpkeepalive|loglevel"
```

Test po poprawce:

Komenda `sshd -T | grep -E "port|maxauthtries|x11forwarding|allowagentforwarding"` potwierdziła, że wszystkie parametry zostały ustawione zgodnie z polityką hardeningu.

```
monikac@d13: ~  
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent  
permitted by applicable law.  
Last login: Fri May 8 08:58:03 2026 from 192.168.0.59  
monikac@d13:~$ su -  
Password:  
root@d13:~# ufw status  
Status: active  
  
To Action From  
--  
2222 ALLOW Anywhere  
2222 (v6) ALLOW Anywhere (v6)  
  
root@d13:~# su -  
root@d13:~# sshd -T | grep -E "port|maxauthtries|x11forwarding|allowagentfor  
warding|tcpkeepalive|loglevel"  
port 2222  
maxauthtries 3  
x11forwarding no  
tcpkeepalive no  
gatewayports no  
allowagentforwarding no  
loglevel VERBOSE  
root@d13:~#
```

3. **Hardening SSH:** Zrzut ekranu z komendy ``sshd -T | grep -E "port|maxauthtries|x11forwarding|allowagentforwarding"`. Widoczny port 2222, limit prób 3 oraz wyłączone opcje X11Forwarding i AllowAgentForwarding.`

Plik: *results/ssh-hardening.png*.

W efekcie otrzymaliśmy redukcję automatycznych ataków, ograniczenie skuteczności ataków brute-force oraz zmniejszenie powierzchni ataku.

Podatność 3: Brak monitorowania integralności i logowania - Identyfikator: FIX-003

System nie posiadał zainstalowanych i aktywnych narzędzi Auditd, AIDE oraz zaawansowanego logowania systemowego rsyslog.

Wykryte zagrożenie jest niepożądane, gdyż atakujący może modyfikować pliki systemowe, ukrywać ślady aktywności i zmieniać konfigurację bez możliwości wykrycia.

Komendy ``systemctl status auditd`` oraz ``aide --check`` wykazały, że usługi są nieaktywne lub niezainstalowane.

W celu minimalizacji ataków zainstalowano i skonfigurowano Auditd z regułami monitorowania plików passwd, shadow oraz sshd_config. Zainstalowano i zainicjalizowano AIDE z bazą danych. Zainstalowano i uruchomiono rsyslog.

AUDITD

Krok 1: Instalacja Auditd

```
apt install auditd -y
```

Krok 2: Włączenie usługi i dodanie do autostartu

```
systemctl enable auditd
```

```
systemctl start auditd
```

Krok 3: Dodanie reguł monitorowania plików

```
nano /etc/audit/rules.d/audit.rules
```

Krok 4: Wprowadzenie reguł:

```
-w /etc/passwd -p wa -k identity
```

```
-w /etc/shadow -p wa -k identity
```

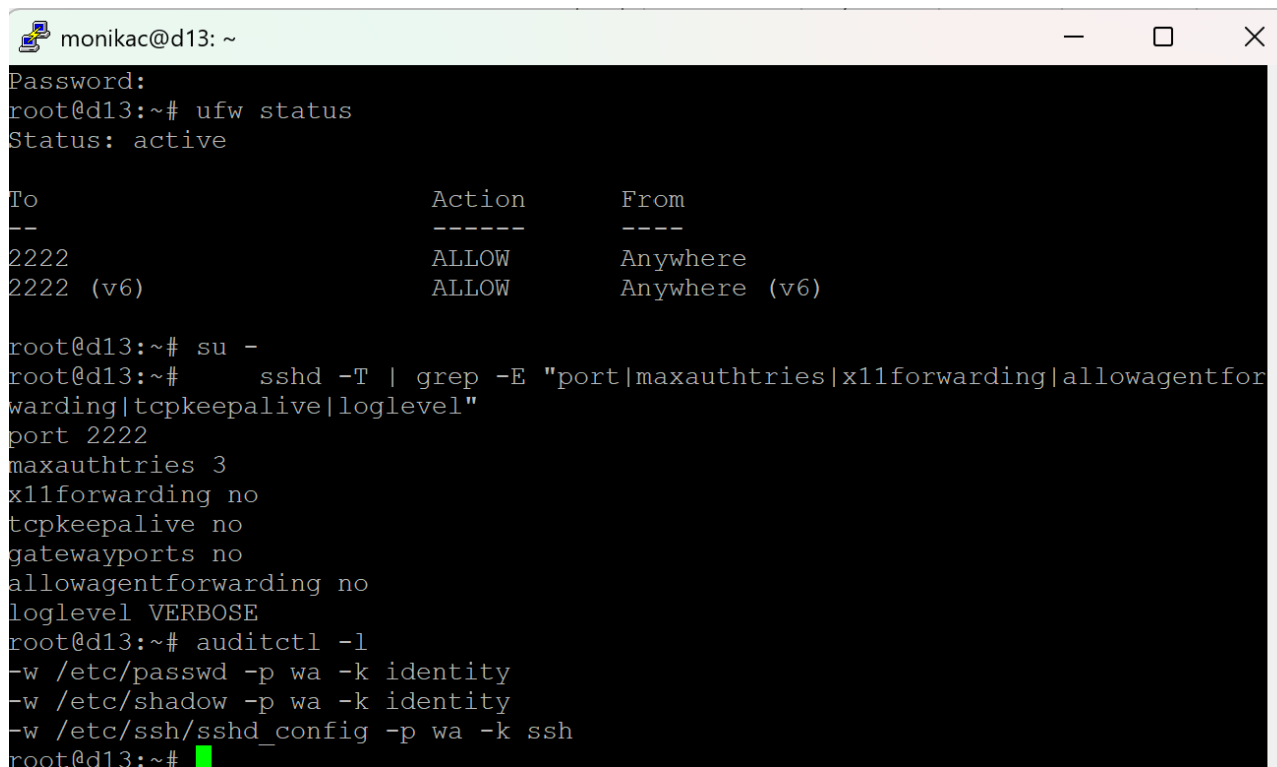
```
-w /etc/ssh/sshd_config -p wa -k ssh
```

Krok 5: Restart Auditd z nowymi regułami

```
systemctl restart auditd
```

Krok 6: Weryfikacja reguł

```
auditctl -l
```



```
monikac@d13: ~
Password:
root@d13:~# ufw status
Status: active

To Action From
--
2222 ALLOW Anywhere
2222 (v6) ALLOW Anywhere (v6)

root@d13:~# su -
root@d13:~# sshd -T | grep -E "port|maxauthtries|x11forwarding|allowagentfor
warding|tcpkeepalive|loglevel"
port 2222
maxauthtries 3
x11forwarding no
tcpkeepalive no
gatewayports no
allowagentforwarding no
loglevel VERBOSE
root@d13:~# auditctl -l
-w /etc/passwd -p wa -k identity
-w /etc/shadow -p wa -k identity
-w /etc/ssh/sshd_config -p wa -k ssh
root@d13:~#
```

4. **Auditd:** Zrzut ekranu z komendy `auditctl -l`. Widoczne aktywne reguły monitorowania plików passwd, shadow oraz sshd_config.

Plik: results/auditd-rules.png.

AIDE

Krok 7: Instalacja AIDE

```
apt install aide -y
```

Krok 8: Inicjalizacja bazy danych

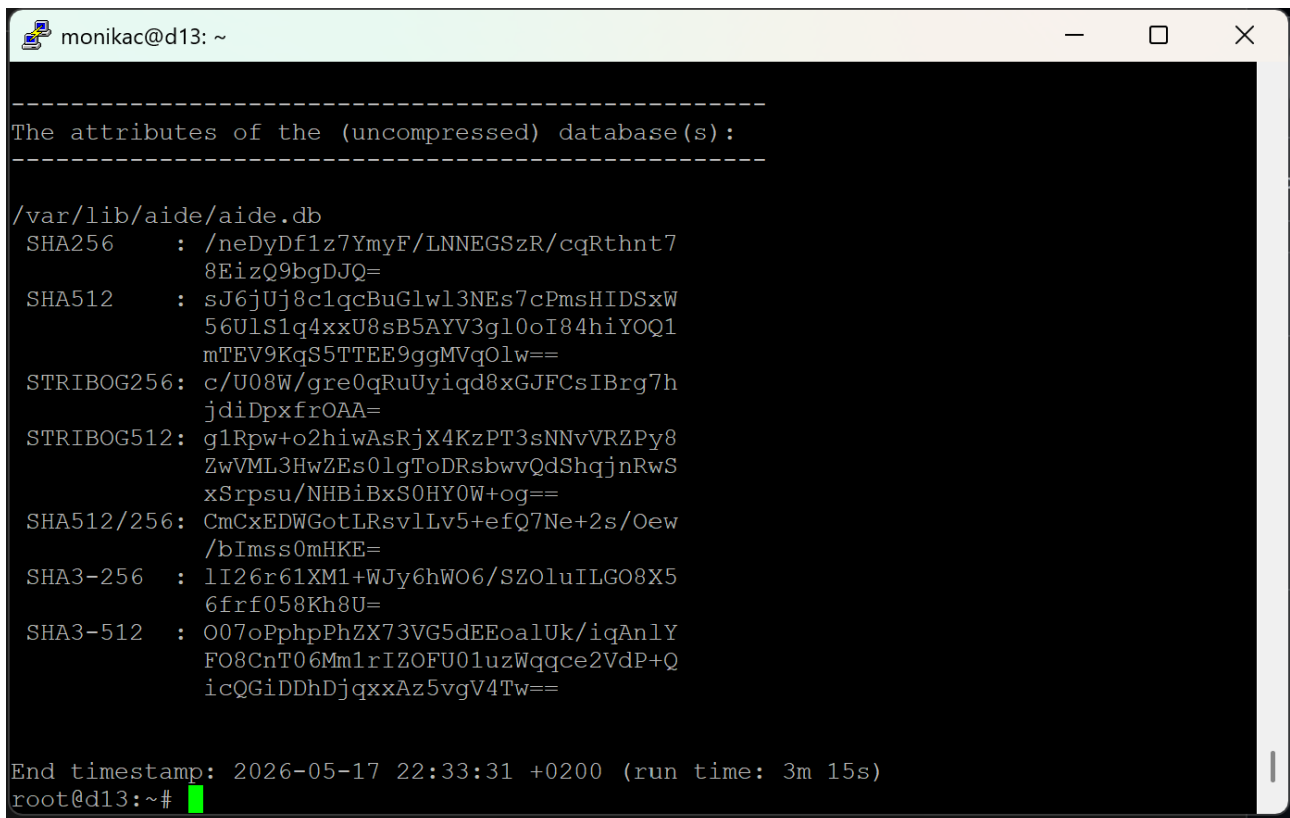
```
aideinit
```

Krok 9: Przeniesienie bazy danych na właściwe miejsce

```
mv /var/lib/aide/aide.db.new /var/lib/aide/aide.db
```

Krok 10: Sprawdzenie integralności plików

```
aide -c /etc/aide/aide.conf --check
```



```
-----
The attributes of the (uncompressed) database(s):
-----

/var/lib/aide/aide.db
SHA256      : /neDyDf1z7YmyF/LNNEGSzR/cqRthnt7
             8EizQ9bgDJQ=
SHA512      : sJ6jUj8c1qcBuGlwl3NEs7cPmsHIDSxW
             56U1S1q4xxU8sB5AYV3gl0oI84hiYOQ1
             mTEV9KqS5TTEE9ggMVqOlw==
STRIBOG256  : c/U08W/gre0qRuUyiqd8xGJFCsIBrg7h
             jdiDpxfrOAA=
STRIBOG512  : g1Rpw+o2hiwAsRjX4KzPT3sNNvVRZPy8
             ZwVML3HwZEs0lgToDRsbwvQdShqjnRwS
             xSrpsu/NHBiBxS0HY0W+og==
SHA512/256  : CmCxEDWGotLRsvlLv5+efQ7Ne+2s/Oew
             /bImss0mHKE=
SHA3-256    : 1I26r61XM1+WJy6hW06/SZ0luILG08X5
             6frf058Kh8U=
SHA3-512    : 007oPphpPhZX73VG5dEEoalUk/iqAnlY
             FO8CnT06Mm1rIZOFU01uzWqqce2VdP+Q
             icQGidDhDjqxxAz5vgV4Tw==

End timestamp: 2026-05-17 22:33:31 +0200 (run time: 3m 15s)
root@d13:~#
```

5. **AIDE:** Zrzut ekranu z komendy `aide -c /etc/aide/aide.conf --check`. Widoczna inicjalizacja bazy danych oraz brak zmian.

Plik: results/aide-check.png.

RSYSLOG

Krok 11: Instalacja Rsyslog

```
apt install rsyslog -y
```

Krok 12: Włączenie i uruchomienie usługi

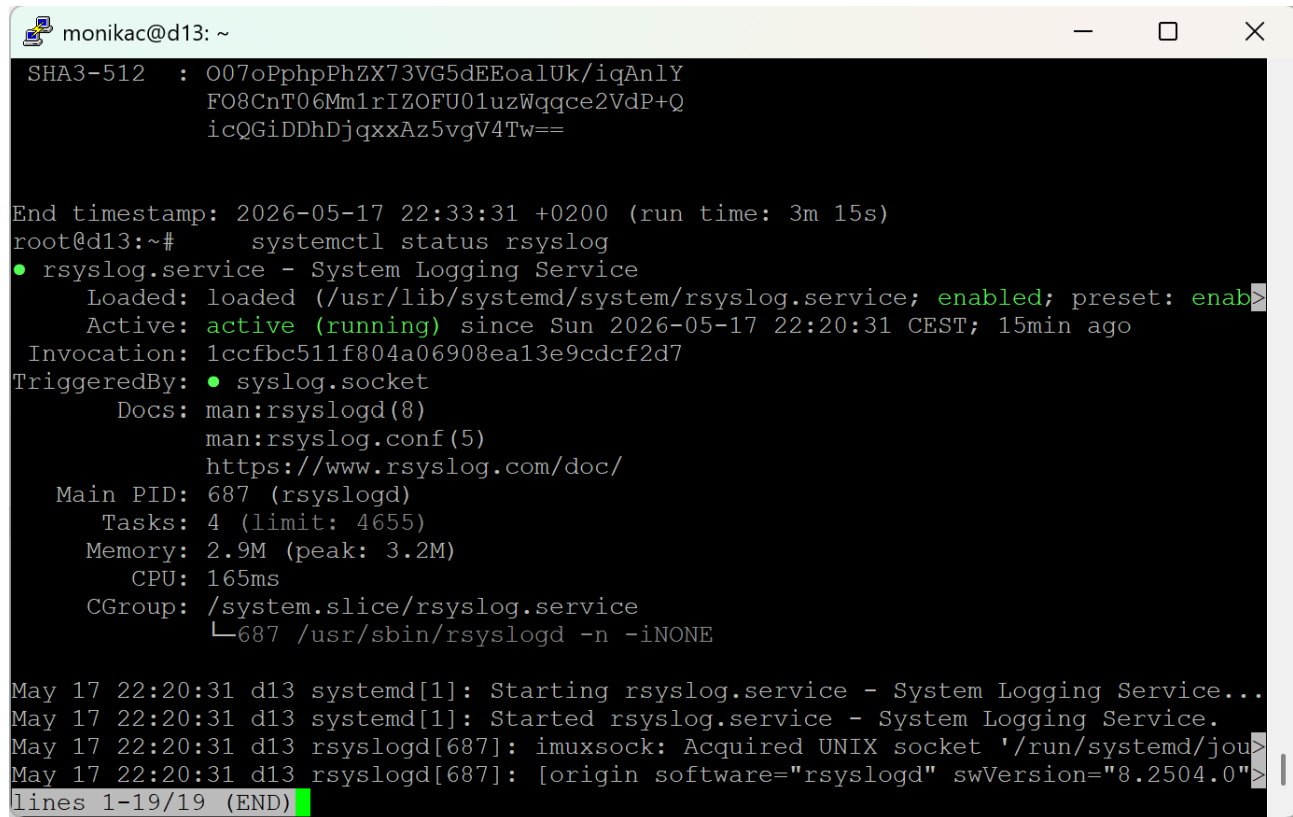
```
systemctl enable rsyslog
```

```
systemctl start rsyslog
```

Krok 13: Weryfikacja statusu

`systemctl status rsyslog`

Komenda `'auditctl -l'` pokazała aktywne reguły monitorowania. Komenda `'aide -c /etc/aide/aide.conf --check'` potwierdziła inicjalizację bazy danych. Komenda `'systemctl status rsyslog'` wykazała, że usługa jest aktywna.



```
monikac@d13: ~
SHA3-512 : 007oPphpPhZX73VG5dEEoalUk/iqAnlY
          FO8CnT06Mm1rIZOFU01uzWqqce2VdP+Q
          icQGidDhDjqxxAz5vgV4Tw==

End timestamp: 2026-05-17 22:33:31 +0200 (run time: 3m 15s)
root@d13:~# systemctl status rsyslog
● rsyslog.service - System Logging Service
   Loaded: loaded (/usr/lib/systemd/system/rsyslog.service; enabled; preset: enab
   Active: active (running) since Sun 2026-05-17 22:20:31 CEST; 15min ago
   Invocation: 1ccfbc511f804a06908ea13e9cdcf2d7
   TriggeredBy: ● syslog.socket
                Docs: man:rsyslogd(8)
                   man:rsyslog.conf(5)
                   https://www.rsyslog.com/doc/
   Main PID: 687 (rsyslogd)
     Tasks: 4 (limit: 4655)
    Memory: 2.9M (peak: 3.2M)
       CPU: 165ms
    CGroup: /system.slice/rsyslog.service
           └─687 /usr/sbin/rsyslogd -n -iNONE

May 17 22:20:31 d13 systemd[1]: Starting rsyslog.service - System Logging Service...
May 17 22:20:31 d13 systemd[1]: Started rsyslog.service - System Logging Service.
May 17 22:20:31 d13 rsyslogd[687]: imuxsock: Acquired UNIX socket '/run/systemd/jou
May 17 22:20:31 d13 rsyslogd[687]: [origin software="rsyslogd" swVersion="8.2504.0">
lines 1-19/19 (END)
```

6. **RSYSLOG:** Zrzut z ekranu – weryfikacja statusu po poprawkach.

Plik: *results/AUDITD.png*

Efekt: System zyskał możliwość wykrywania nieautoryzowanych zmian w krytycznych plikach, rejestrowania incydentów bezpieczeństwa oraz zwiększenia widoczności zdarzeń systemowych.

5. Wyniki audytu – przed i po

Przed wdrożeniem poprawek system uzyskał w audycie Lynis wynik 63 punkty na 100. Wykryto 1 ostrzeżenie dotyczące braku drugiego serwera DNS oraz 47 sugestii optymalizacyjnych. Wykonano 251 testów.

```
monikac@d13: ~  
-----  
- Show details of a test (lynis show details TEST-ID)  
- Check the logfile for all details (less /var/log/lynis.log)  
- Read security controls texts (https://cisofy.com)  
- Use --upload to upload data to central system (Lynis Enterprise users)  
-----  
  
Lynis security scan details:  
  
Hardening index : 63 [##### ]  
Tests performed : 251  
Plugins enabled : 1  
  
Components:  
- Firewall [V]  
- Malware scanner [X]  
  
Scan mode:  
Normal [V] Forensics [ ] Integration [ ] Pentest [ ]  
  
Lynis modules:  
- Compliance status [?]  
- Security audit [V]  
- Vulnerability scan [V]  
  
Files:  
- Test and debug information : /var/log/lynis.log  
- Report data : /var/log/lynis-report.dat  
  
-----  
  
Lynis 3.1.4  
  
Auditing, system hardening, and compliance for UNIX-based systems  
(Linux, macOS, BSD, and others)  
  
2007-2024, CISOfy - https://cisofy.com/lynis/  
Enterprise support available (compliance, plugins, interface and tools)  
-----
```

7. Audyt początkowy: Zrzut ekranu z wynikiem audytu Lynis przed hardeningiem. Widoczny wynik 63 punkty.

Plik: results/1.Lynis-audyt.png.

Po wdrożeniu wszystkich 11 poprawek system uzyskał wynik 82 punkty na 100. Wszystkie ostrzeżenia zostały wyeliminowane. Liczba sugestii spadła do 31. Wykonano 262 testy.

```
monikac@d13: ~  
-----  
  
Lynis security scan details:  
  
Hardening index : 82 [##### ]  
Tests performed : 262  
Plugins enabled : 1  
  
Components:  
- Firewall [V]  
- Malware scanner [X]  
  
Scan mode:  
Normal [V] Forensics [ ] Integration [ ] Pentest [ ]  
  
Lynis modules:  
- Compliance status [?]  
- Security audit [V]  
- Vulnerability scan [V]  
  
Files:  
- Test and debug information : /var/log/lynis.log  
- Report data : /var/log/lynis-report.dat  
  
-----  
  
Lynis 3.1.4  
  
Auditing, system hardening, and compliance for UNIX-based systems  
(Linux, macOS, BSD, and others)  
  
2007-2024, CISOfy - https://cisofy.com/lynis/  
Enterprise support available (compliance, plugins, interface and tools)  
-----  
  
[TIP]: Enhance Lynis audits by adding your settings to custom.prfl (see /etc/lynis/default.prfl for al  
l settings)  
root@d13:~#
```

8. Audyt końcowy: Zrzut ekranu z wynikiem audytu Lynis po hardeningu. Widoczny wynik 82 punkty na 100 oraz brak ostrzeżeń.

Plik: results/2.Lynis-audyt.png

Wzrost o 19 punktów oznacza poprawę bezpieczeństwa o około 30 procent w skali Lynis. Największy wpływ na poprawę wyniku miały wdrożenie firewalla UFW, hardening konfiguracji SSH, instalacja Fail2ban, wdrożenie Auditd i AIDE oraz hardening parametrów jądra systemu.

6. Automatyzacja audytu

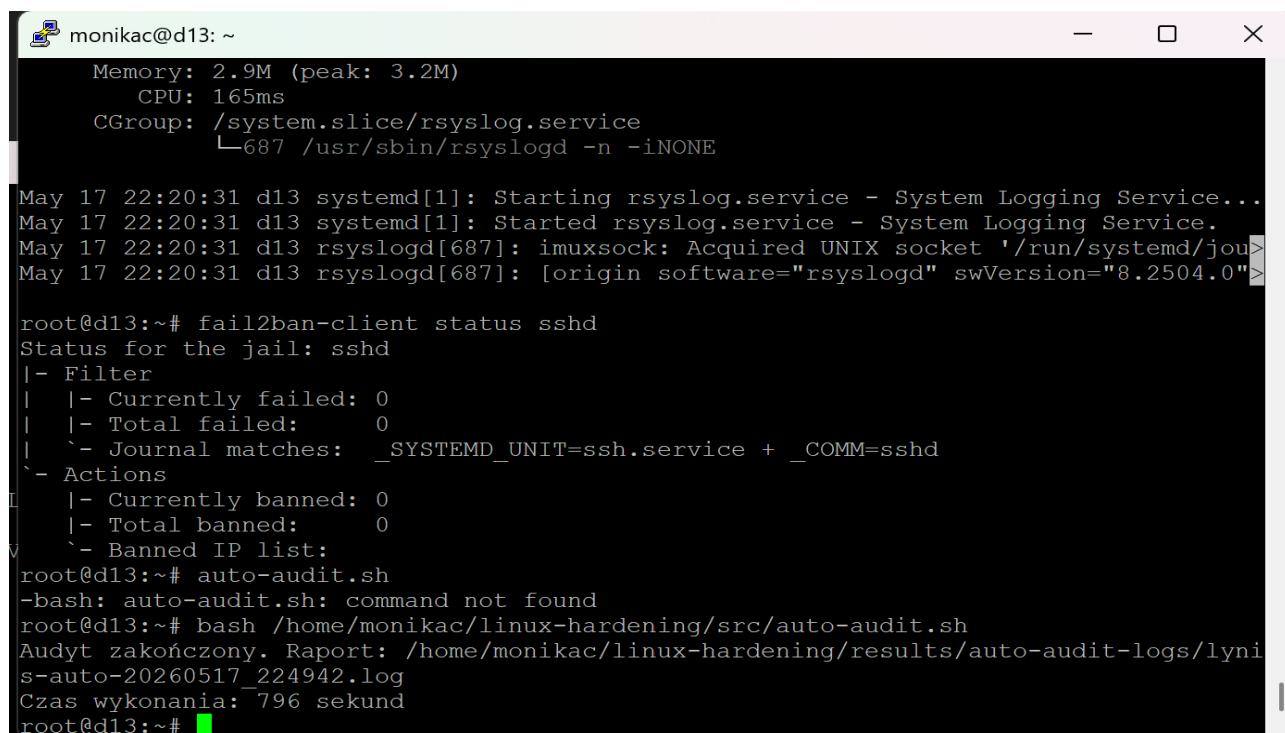
W celu zapewnienia regularności i oszczędności czasu zautomatyzowano cotygodniowy audyt Lynis. Przygotowano skrypt `auto-audit.sh`, który wykonuje pełny audyt, mierzy czas wykonania i zapisuje raport z datą w nazwie. Skrypt został zaplanowany w CRONie i uruchamia się automatycznie w każdą niedzielę o godzinie 23:59.

Ręczne wykonanie audytu zajmowało około 2 do 3 minut aktywnej pracy człowieka. Po automatyzacji czas aktywnej pracy człowieka wynosi 0 sekund – skrypt działa w tle. W skali roku daje to oszczędność około 2 do 3 godzin.

8. Wnioski końcowe

Projekt zakończył się pełnym sukcesem. Wszystkie założone cele zostały osiągnięte. Wdrożone działania hardeningowe znacząco zwiększyły bezpieczeństwo systemu, podnosząc wskaźnik Lynis z 63 do 82 punktów. Wszystkie ostrzeżenia zostały wyeliminowane. System zyskał ochronę przed atakami sieciowymi dzięki aktywnemu firewallowi, ochronę przed atakami brute-force dzięki Fail2ban, możliwość wykrywania nieautoryzowanych zmian dzięki Auditd i AIDE oraz regularne audyty dzięki automatyzacji przez CRON.

Końcowy wynik audytu 82 punkty na 100 potwierdza, że system po hardeningu spełnia podstawowe, a w wielu obszarach zaawansowane, wymagania bezpiecznej konfiguracji środowiska Linux.



```
monikac@d13: ~
Memory: 2.9M (peak: 3.2M)
CPU: 165ms
CGroup: /system.slice/rsyslog.service
└─687 /usr/sbin/rsyslogd -n -iNONE

May 17 22:20:31 d13 systemd[1]: Starting rsyslog.service - System Logging Service...
May 17 22:20:31 d13 systemd[1]: Started rsyslog.service - System Logging Service.
May 17 22:20:31 d13 rsyslogd[687]: imuxsock: Acquired UNIX socket '/run/systemd/jou>
May 17 22:20:31 d13 rsyslogd[687]: [origin software="rsyslogd" swVersion="8.2504.0">

root@d13:~# fail2ban-client status sshd
Status for the jail: sshd
|- Filter
| |- Currently failed: 0
| |- Total failed: 0
| `-- Journal matches: _SYSTEMD_UNIT=ssh.service + _COMM=sshd
`- Actions
    |- Currently banned: 0
    |- Total banned: 0
    `-- Banned IP list:
root@d13:~# auto-audit.sh
-bash: auto-audit.sh: command not found
root@d13:~# bash /home/monikac/linux-hardening/src/auto-audit.sh
Audyty zakończony. Raport: /home/monikac/linux-hardening/results/auto-audit-logs/lyni
s-auto-20260517_224942.log
Czas wykonania: 796 sekund
root@d13:~#
```

9. *AUTO_AUDIT.SH*: Zrzut z ekranu działania skryptu (manualne uruchomienie)

Plik: results/SKRYPT-SH.png

9. Załączniki

Wszystkie logi i raporty z narzędzia Lynis przed i po hardeningu.

Zrzuty ekranu potwierdzające wdrożenie poszczególnych poprawek.

Skrypt automatyzujący audyt auto-audit.sh.

Pełna dokumentacja znajduje się w repozytorium GitHub pod adresem:

<https://github.com/MCampoli/linux-hardening>